

Security Headers Cheat Sheet

Core headers worth setting

- Content-Security-Policy — restricts what sources scripts/styles/images can load from.
- X-Content-Type-Options: nosniff — stops the browser guessing file types.
- Referrer-Policy: strict-origin-when-cross-origin — limits what leaks in the referrer.
- Permissions-Policy — explicitly turns off camera/mic/geolocation you don't use.

Where to set them

- Netlify / Cloudflare Pages: a plain-text _headers file at your site root.
- GitHub Pages: no server config access — use an equivalent <meta http-equiv> tag instead for CSP.
- Custom server (nginx/Apache): set headers directly in the server config.

Quick sanity check

- After deploying, run your domain through securityheaders.com to see your grade.
- Start with a loose CSP and tighten it once you confirm nothing breaks.